

TOM DENEYER

ANASTASIIA KOZLENKO

Connecting Networks BAC3
2025

Email : tomdeney@gmail.com
Discord : Littl3T

Table des matières

Monitoring Réseau.....	5
Généralités.....	5
Syslog.....	7
SNMP.....	8
Netflow.....	9
AAA.....	10
Méthodes d'authentification sur l'équipement réseau.....	10
Fonctions AAA.....	10
Configuration.....	10
Authentication.....	10
Méthodes d'authentification supportées :	10
Authorization.....	11
Comptabilisation.....	12
Serveurs AAA.....	13
Configuration Radius.....	13
FreeRadius.....	13
Configuration TACACS+.....	13
Analyse de configuration.....	14
802.1X.....	15
Protocoles de transport.....	16
Configuration.....	17
Port Mirroring.....	18
Configuration.....	19
VRF.....	20
Configuration.....	20
Qualité de service.....	21
Caractéristiques de différent trafic.....	21
La mise en file d'attente.....	22
Modèles d'implémentation QoS.....	24
Prévention de la congestion.....	24
Outils de classification (analyse) et marquage (ajout d'en-tête).....	24
Traitement des paquets.....	25
Frontières de confiance (trust boundary).....	27
Pentesting.....	28
Les systèmes de détection.....	28
Phase 1 : Pre-engagement interactions.....	28
Phase 2 : Intelligence Gathering.....	29
Scan du réseau.....	30

Scan Idle	32
Phase 3 : Threat Modeling (Modélisation des menaces)	33
Phase 4 : Vulnerability Analysis (Analyse des vulnérabilités)	33
Phase 5 : Exploitation	33
Phase 6 : Post-exploitation	33
Phase 7 : Reporting	34
Les Antennes	35
Généralités	35
Types d'antennes	36
Types d'onde	37
L'onde radio (Radio wave)	37
Les incidents de propagation	38

Monitoring Réseau

Généralités

Monitoring - le fait de surveiller en temps réel l'état et les performances d'un système pour connaître l'état actuel et son historique.

Métrologie – ensemble des méthodes et des techniques pour mesurer l'état du système.

Supervision - analyse les données collectées pour comprendre les tendances, anticiper les problèmes et optimiser les performances.

Network baseline – une ligne de base du réseau, le fonctionnement normal.

Pourquoi superviser ?

- Avoir les données sur le fonctionnement de réseau et des services
- Avoir un historique
- Être alerté

Superviser quoi ?

Tout ce qui est utile, mais pas trop pour ne pas surcharger le système.

Exemples :

- le % de bande passante utilisée,
- le % de paquets en erreur,
- le % de paquets de diffusion,
- la température,
- les ports en erreur,
- la mémoire utilisée,
- le CPU utilisé,
- les authentifications incorrectes,
- l'état des services
- sait-on lire un mot sur un site web ?

Superviser comment ?

Méthode active : **polling (sondage)**

- Requête de la station de gestion – réponse du périphérique en continu.
- Délai entre l'occurrence d'un événement et l'heure de journalisation.
- Consomme des ressources tout le temps

Méthode passive : **trap (déroutement)**

- L'équipement prévient qu'un événement particulier s'est produit.

Alertes

- limiter les alarmes, temporiser, message clair
- classer par importance
- seules les bonnes personnes sont alertées
- afficher / mail / SMS
- éviter les cascades d'alarmes

Actions de correction – scripter la réaction aux problèmes, ex. redémarrer un service.

À long terme sauvegarder que des informations généralisées, ex. la plupart du temps de l'année 2025 CPU est à 60%.

Protocoles : Syslog, SNMP, NetFlow/IPfix

Outils :

- PRTG network monitor
- SolarWindsNetwork Performance Monitor
- Nagios
- Zabbix
- Kiwi syslog
- Serveur Syslog Tftpd32
- SolawindsNetFlowTraffic Analyzer

Pour comparer les outils définir les « Must have » et « Best to have », lister les fonctionnalités pour chaque outil.

Must-Have	Nice-To-Have
Auto Discovery du réseau	Prédictibilité de pannes
Interface web	Analyse des comportements inhabituels
Interface de gestion simple et intuitive	Gestion des alertes (corrélation, escalation,...)
Utilisateur viewer (read-only)	Serveur de centralisation des logs
Monitoring réseau	Système de ticket interne
Budget de xx € HTVA	
Windows Server 2016 et 2022	Imprimantes
Ubuntu 20.04 et 22.04	Access point de marque XX
Hyperviseur XX	Bancontact
Serveurs web (MySQL, Apache, PHP, requêtes HTTP)	Caisses
Contrôleur de domaine (Active Directory, DHCP, DNS)	Caméras
Switches XX	Antivirus XX
Microsoft Exchange (Backup, envoi de mail)	Solution de Backup XX
Firewall FortiGate	
UPS	
Pointeuses	
Badge	

	Zabbix	Nagios XI	PRTG	NetCrunch
Utilisation de l'Auto Discovery	+	++	+	++
Performance de l'Auto Discovery	---	+	+++	=
Interface web	+	++	+++	--
Facilité de gestion	---	-	++	NE
Facilité de lisibilité des éléments et alertes	NE	+	+++	-
Interface intuitive	---	-	+++	-
Gestion des utilisateurs	NE	=	+	NE
Gestion des alertes (corrélation, escalation,...)	NE	---	+	NE
Gestion des alertes (downtime, acknowledge,...)	NE	++	=	NE
Fonctionnalités supplémentaires (xFlow, maps,...)	NE	NE	+	++
Performance (Interface, lenteur, scans,...)	+	++	--	---
Communauté et assistance	--	++	++	--
Durée d'implémentation (estimation)	NE	-	++	NE
Ressenti personnel	--	-	++	---
Légende : de --- à +++, +++ étant le meilleur, NE : fonctionnalité Non Expérimentée				

Total cost of ownership (TCO) comprend toutes les dépenses liées à l'achat et l'utilisation de la solution.

Syslog

Un système de journalisation existant par default sur les périphériques.

Port UDP 514

```
R1(config-if)#
*Mar 1 01:16:08.212: %LINK-3-UPDOWN: Interface
FastEthernet0/0, changed state to up
*Mar 1 01:16:09.214: %LINEPROTO-5-UPDOWN: Line protocol on
Interface FastEthernet0/0, changed state to up
```

Destination des messages syslog :

- Dans une mémoire tampon sur le périphérique **logging buffered**
 - Les données ne sont accessibles que par la CLI.
 - Les messages de niveau débogage ne sont transférés que vers le tampon interne.
- Dans la console (console 0) (par default) **logging console**
- Dans un terminal (vty) **logging terminal**
- Vers un serveur syslog sur le réseau.

```
Sw(config)# logging host 192.168.1.3
```

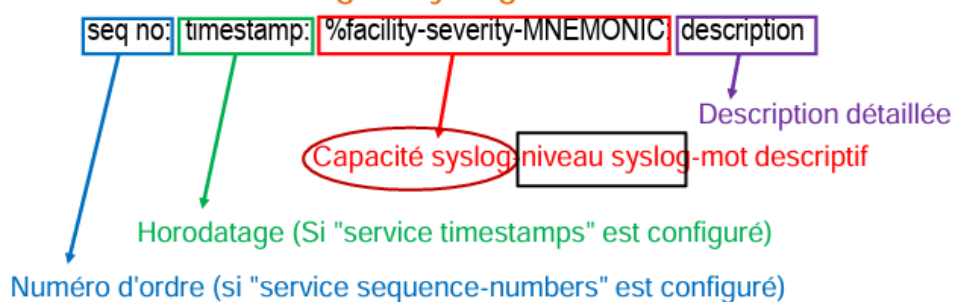
```
Sw(config)# logging trap level
```

```
Sw(config)# logging trap 4
```

```
Sw(config)# logging trap warning
```

Gravité Cisco	Niveau	Syslog	Descriptif
Emergencies (Urgence)	0	LOG_EMERG	Système instable
Alerts (Alerte)	1	LOG_ALERT	Action immédiate requise
Critical (Critique)	2	LOG_CRIT	Conditions critique
Errors (Erreur)	3	LOG_ERR	Conditions d'erreur
Warnings (Avertissement)	4	LOG_WARNING	Condition d'avertissement
Notifications (Notification)	5	LOG_NOTICE	Événement normal mais important
Informational (Informatif)	6	LOG_INFO	Message informatif
Debugging (Débogage)	7	LOG_DEBUG	Message de débogage

P. ex. Interface change state to up



— Exemple

```
Router(config-if)# no shutdown
```

```
%LINK-5-CHANGED: Interface FastEthernet0/0, changed state to up
```

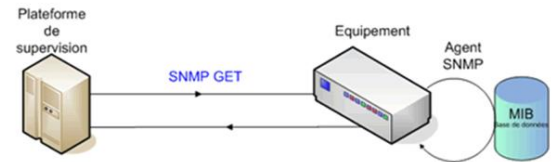
```
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/0, changed state to up
```

*Configurer NTP pour avoir une bonne heure des logs

- gérer les équipements du réseau (modification de la configuration),
- superviser les équipements du réseau (récolte, vérification de données, de config.),
- diagnostiquer des problèmes réseaux (via l'analyse des données récoltées)

Le système SNMP se compose de

- Le gestionnaires SNMP (SNMP manager, NMS (Network Management Server)).
- Les agents SNMP (SNMP agent).
- Les bases d'informations de gestion (MIB) avec une structure arborescente.



MIB :

- Les éléments de la MIB sont appelés "objets".
- Un fichier MIB est un document texte écrit en langage ASN.1
- Les objets peuvent être
 - **Statiques** (Type de matériel, constructeur, version d'un équipement)
 - **Dynamiques** - État à un instant donné (up, down, ...).
 - **Statistiques** - Minuteurs, compteurs, ... (uptime, nombre d'octets reçus sur un port, etc.).
- MIB Browser – Logiciel permettant d'explorer une arborescence MIB

Versions SNMP :

- SNMPv1 (1987) : sécurité très faible, basée sur une community string pour mdp envoyée en clair.
- SNMPv2c (1993) : améliorations fonctionnelles (compteurs 64 bits, getbulk, meilleure gestion d'erreurs), compatible v1, mais sécurité toujours limitée (community en clair).
- SNMPv3 : version sécurisée avec authentification, intégrité, anti-rejeu et chiffrement, adaptée aux réseaux étendus.

3 niveaux de sécurité de v3 :

- noAuthNoPriv (noauth)
 - Authentification : le nom d'utilisateur remplace la communauté SNMP
 - Pas de chiffrement.
- AuthNoPriv (auth)
 - Authentification via HMAC-MD5 ou HMAC-SHA.
 - Pas de chiffrement.
- AuthPriv (priv)
 - Authentification via HMAC-MD5 ou HMAC-SHA.
 - Chiffrement (DES, 3DES ou AES).

Netflow

Protocole Cisco. Collecte des informations sur les flux IP qui traversent un R ou un L3.

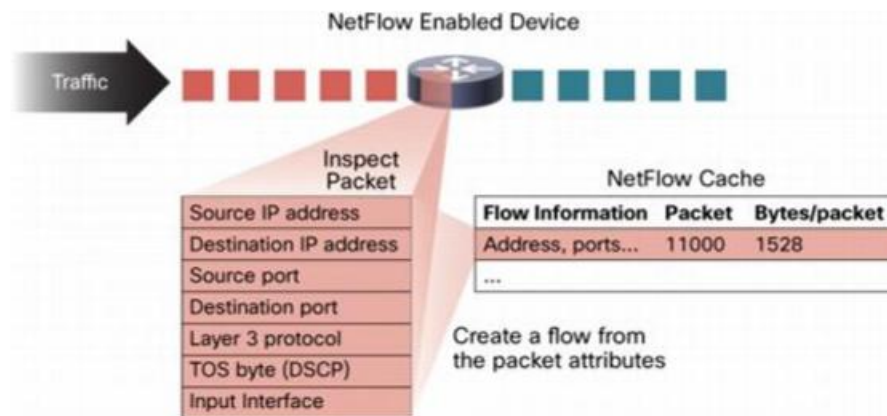
Collecteur NetFlow - nom du serveur externe où sont envoyées les statistiques Netflow. N'envoie jamais de requêtes netflow aux périphériques. Peut implémenter des fonctionnalités afin d'agir sur les périphériques selon l'analyse des données Netflow.

Flexible NetFlow - nom donné à la version la plus récente du protocole NetFlow de Cisco. Permettent de définir les champs pour distinguer un flux d'un autre et de spécifier quelles données doivent être envoyées au collecteur (sinon Netflow v5 collecte toujours les mêmes données)

IPFIX - version standardisées IETF basée sur flexible Netflow.

Flux TCP/IP :

- Un flux TCP/IP correspond à un échange unidirectionnel de paquets entre une source et une destination.
- NetFlow (v5) classe le trafic en flux selon 7 champs : IP source, IP destination, port source, port destination, protocole L3, champ TOS(type de service), interface logique d'entrée.
- Deux paquets appartiennent au même flux si ces sept champs sont identiques.
- Le périphérique construit une table des flux qu'il stocke en cache.



Le flux s'arrête

- Lorsque le flux est inactif (inactive timer de 15s. par défaut).
- Lorsque le flux est trop long (30 min. par défaut).
- Lorsque la session s'arrête (TCP flag RST, FIN).

Une fois le flux arrêté

- Netflow l'exporte vers un collecteur Netflow.
- Les données sont envoyées au collecteur dans le format d'exportation configuré.

Méthodes d'authentification sur l'équipement réseau

Authentification locale sans AAA

- Uniquement via un mdp - on ne sait pas qui s'est connecté en personne.
- Via username/mdp - chaque périphérique doit être configuré séparément

DB locale sans AAA – lourdeur administrative, pas d'authentification de secours (fallback)

Local AAA – DB local, mais avec fallback

Authentification centralisée

- Server-Based AAA Authentication – username/mdp sont stockées sur un serveur.
- Protocoles : RADIUS (Remote Authentication Dial-In User Service) et TACACS+ (Terminal Access Controller Access-Control System Plus.)

Fonctions AAA

1. **Authentication** - Contrôler quels utilisateurs sont autorisés à s'y connecter
 - L'authentification forte consiste à utiliser au moins deux facteurs différents, ex. un mdp et un badge.
2. **Authorization** - Contrôler ce que les utilisateurs sont autorisés à faire, pour chaque action de l'utilisateur, une requête est envoyée au serveur AAA pour vérifier les permissions.
3. **Accounting/Auditing** - permet d'enregistrer des données sur l'utilisation des systèmes : compte utilisateur, temps de connexion, commandes exécutées, etc. Ces données sont utilisées à des fins de facturation, d'audit et/ou de dépannage.

Configuration

Authentication

Ajouter les noms d'utilisateurs et les mots de passe à la DB locale :

```
R(config)# username nomducompte algorithm-type scrypt secret mdp
```

Activer AAA au niveau du routeur :

```
R(config)# aaa new-model
```

- Applique immédiatement l'authentification locale à toutes les lignes et interfaces (excepté la console).
- Il est donc conseillé de définir un nom d'utilisateur et un mot de passe *avant* de commencer la configuration AAA, sinon on peut perdre la connexion.

Appliquer l'authentification AAA :

```
R(config)#line [aux | console | tty | vty] lineNumber [end-line-N°]
```

```
R(config-line)# login authentication {default | list-name}
```

- default: indique qu'il s'agit du type d'authentification par défaut à appliquer sur toutes les lignes.
- list-name: nom donné à la liste des méthodes en train d'être créée. La création d'une liste est prioritaire par rapport à l'authentification par défaut.

method: il est possible de définir jusque 4 méthodes d'authentification (fallback). Si une méthode ne fonctionne pas, passe à la prochaine.

Méthodes d'authentification supportées :

- **enable**: utilise le mdp défini par "enable password" (secret).
- **krb5**: utilise Kerberos5 pour l'authentification.
- **krb5-telnet**: utilise Kerberos5 pour authentifier une connexion telnet.
- **line**: utilise le mdp défini dans la configuration "line".
- **local**: utilise le couple login/password, seul le mdp étant sensible à la casse.

- **local-case**: utilise le couple login/password sensible à la casse.
- **none**: pas d'authentification, toutes les demandes sont acceptées.
- **groupe radius**: utilise la liste des serveurs RADIUS pour l'authentification.
- **groupe tacacs+**: utilise la liste des serveurs TACACS+ pour l'authentification.
- **group groupe-name**: utilise un sous-ensemble de serveurs défini par une commande "aaa group server radius" or "aaa group server tacacs+".

Permet de revenir à la méthode d'authentification par défaut : `no authentication login`

Définir une nouvelle méthode et l'appliquer :

```
R(config) aaa authentication login SSH-LOGIN local-case
```

```
R(config) line vty 0 4
```

```
R(config-line) login authentication SSH-LOGIN
```

Verrouiller l'accès à un compte après un certain nombre de tentatives de connexion échouées :

```
R(config)# aaa local authentication attempts max-fail number
```

Configurer un délai entre deux tentatives de connexion :

```
R(config)# login seconds
```

Lister les comptes verrouillés

```
R(config)# show aaa local user lockout
```

Déverrouiller les comptes bloqués :

```
R(config)# clear aaa local user lockout [all | username]
```

Unique ID

- Si un utilisateur se connecte en utilisant AAA, une session est établie et est associée à un numéro de session unique (Unique ID).
- Les attributs de la session AAA sont enregistré dans la DB AAA.

```
R1# sho aaa sessions
Total sessions since last reload: 1
Session Id:1
           Unique Id:1
           User Name:admin
           IP Address:10.2.1.2
           Idle Time: 0
           CT Call Handle: 0
```

```
R# debug aaa authentication
```

```
R1# debug aaa authentication
113123: Feb 4 10:11:19.305 CST: AAA/MEMORY: create_user (0x619C4940) user='ruser='
port='tty1' rem_addr='asyn/81560' authen_type=ASCII service=LOGIN priv=1
113124: Feb 4 10:11:19.305 CST: AAA/AUTHEN/START (2784097690): port='tty1' list='
action=LOGIN service=LOGIN
113125: Feb 4 10:11:19.305 CST: AAA/AUTHEN/START (2784097690): using "default" list
113126: Feb 4 10:11:19.305 CST: AAA/AUTHEN/START (2784097690): Method=LOCAL
113127: Feb 4 10:11:19.305 CST: AAA/AUTHEN (2784097690): status = GETUSER
113128: Feb 4 10:11:26.305 CST: AAA/AUTHEN/CONT (2784097690): continue_login
(user='(undef)')
113129: Feb 4 10:11:26.305 CST: AAA/AUTHEN (2784097690): status = GETUSER
113130: Feb 4 10:11:26.305 CST: AAA/AUTHEN/CONT (2784097690): Method=LOCAL
113131: Feb 4 10:11:26.305 CST: AAA/AUTHEN (2784097690): status = GETPASS
113132: Feb 4 10:11:28.145 CST: AAA/AUTHEN/CONT (2784097690): continue_login
(user='diallocal')
113133: Feb 4 10:11:28.145 CST: AAA/AUTHEN (2784097690): status = GETPASS
113134: Feb 4 10:11:28.145 CST: AAA/AUTHEN/CONT (2784097690): Method=LOCAL
113135: Feb 4 10:11:28.145 CST: AAA/AUTHEN (2784097690): status = PASS
```

Authorization

```
R(config)# aaa authorization{ network | exec | commandos level}{ default | liste-name} method1 ...[ method4]
```

- **network**: permet d'autoriser des services réseau (par exemple PPP).
- **exec**: permet d'autoriser l'exécution d'un shell.
- **command**: permet d'autoriser l'exécution de commandes shell.

Par défaut, aaa authorization n'est pas activé → tous les utilisateurs ont accès à tout. Une fois aaa authorization activé, par défaut plus aucun accès n'est autorisé.

Méthodes d'autorisations supportées inclus RADIUS, TACACS+, local, none et **If-Authenticated** en plus - si l'utilisateur a été authentifié avec succès, il est d'office autorisé à accéder à la fonction demandée.

Comptabilisation

Pourquoi comptabiliser?

- Pour facturer l'utilisation de ressources.
- Les utilisateurs étant "surveillés", ils font plus attention.
- Pour détecter des actions suspectes voir interdites.
- Pour mieux cibler la source d'un problème et intervenir.
- Pour avoir une trace légale des actions effectuées sur un système de l'entreprise.

Comptabiliser quoi?

- Les commandes exécutées.
- Les temps de connexion.
- Le volume de données (nombres d'octets transmis).
- Les informations sur les connexions Telnet ou SSH (qui, quand, ...).
- Les événements systèmes (lorsque le système redémarre par exemple).

```
R(config)# aaa accounting { network | exec | command | connection } { default | liste-name } { start-stop | stop-only | none } [broadcast] method1 ... [method4]
```

Options :

- **network**: active la comptabilisation sur les services réseau. Par exemple comptabilise le nombre de paquets transmis lors d'une session PPP.
- **exec**: active la comptabilisation sur les sessions shell. Comptabilise "le nom d'utilisateur, la date, les dates (start et stop), et l'adresse IP d'une session shell.
- **command**: active la comptabilisation sur les commandes du mode EXEC. Enregistre la liste des commandes exécutées pour un niveau de privilège déterminé, la date d'exécution et l'utilisateur qui a exécuté la commande.
- **connection**: active la comptabilisation sur les connexions sortantes (ssh).

Indique quand la comptabilisation doit commencer/arrêter les enregistrements :

- **Start-stop** : » Fourni des enregistrement "start" une fois la phase d'authentification réussie et "stop" à la fin du processus.
- **Stop-only** : » Envoie une notification "stop" à la fin du processus utilisateur.
- **None** : » désactive la comptabilisation sur une ligne ou une interface.

Broadcast: Permet d'envoyer les informations de comptabilisation vers plusieurs serveurs AAA.

Serveurs AAA

Critère	TACACS+	RADIUS
Usage typique	Administration des équipements (accès CLI aux routeurs/switches/firewalls)	Accès réseau utilisateurs (VPN, Wi-Fi 802.1X/EAP, PPPoE, NAC)
Chiffrement	Chiffre tout le corps du paquet (seul l'entête reste lisible)	Ne chiffre que le mot de passe (MD5) ; le reste des AVP est en clair (<i>sauf RADIUS/TLS – “RadSec”</i>)
Granularité d'autorisation	Très fine : contrôle par commande (ex. show, conf t, write)	Par profil/attributs (VSA), moins adapté au par-commande
Tolérance aux pertes	TCP → retransmissions, sessions	UDP → rapide mais perte possible
Standard	Cisco, mais standardisé et supporté	standard IETF (RFC 2865/2866, 5176, 6614...)

Configuration Radius

```
R(config)# aaa new-model
```

```
R(config)# radius-server host 192.168.0.1 auth-port 1812 acct-port 1813
```

- Si plusieurs serveurs Radius, une commande par serveur.
- Auth-port : N° du port utilisé pour l'authentification.
- acct-port : N° du port utilisé pour la comptabilisation.
- Les ports sont 1645 et 1646 par défaut. L'IANA a réservé les ports 1812 (authentication) et 1813 (accounting).

Configurer la clé privée pour l'encryption :

```
R(config-radius-server)# key r@dius-sh@red-key
```

```
R(config)#radius host 192.168.0.230 key r@dius-sh@red-key
```

FreeRadius

- Serveur RADIUS open source
- Peut être utilisé avec plusieurs sources d'identités (LDAP, AD, SQL, ...).
- Supporte plusieurs méthodes d'authentification (EAP/TLS, PEAP, ...).
- Multi-plateforme (Linux, FreeBSD, macOS, ...)

Utilisé par les FAI pour authentifier des utilisateurs lors de connexions DSL, par les entreprises pour l'authentification d'utilisateurs réseau filaire ou sans fil, par Eduroam.

Configuration TACACS+

```
R(config)# aaa new-model
```

```
Router(config)#tacacs-server host IPorNAME [single-connection] [port integer] [timeout integer] [key string]
```

- *IPorNAME* : adresse IP ou FQDN du serveur TACACS+ à contacter.
- *single-connection (optionnel)* : garde une connexion TCP persistante ouverte vers le serveur (au lieu d'ouvrir/fermer à chaque requête).
- *port integer (optionnel)* : port TCP du serveur. Par défaut : 49.
- *timeout integer (optionnel)* : délai d'attente (en s, par default 5s) avant de considérer la tentative échouée et d'essayer le serveur suivant / le fallback local.
- *key string (optionnel)* : secret partagé avec ce serveur

Possibilité d'empiler les méthodes :

```
R(config)# aaa authentication login default group tacacs+ group radius local-case
```

- Tentative d'authentification avec un serveur TACACS+, ensuite avec un serveur RADIUS, ensuite en utilisant la base de données locale.
- Attention basculement uniquement si le serveur n'est pas accessible, le service n'est pas up, si on reçoit un refus à cause d'une mauvaise config, ça ne va pas basculer.

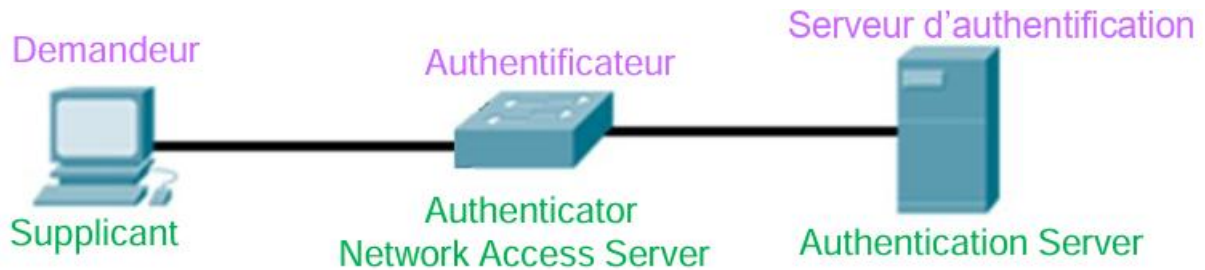
Analyse de configuration

• Exemple de configuration AAA

```
R(config)# aaa new-model
R(config)# aaa authentication login default group radius local
R(config)# aaa authentication enable default group radius enable
R(config)# aaa authorization config-commands
R(config)# aaa authorization exec default group radius local if-
authenticated
R(config)# aaa authorization commands 1 default group radius if-
authenticated
R(config)# aaa authorization commands 15 default group radius
local if-authenticated
R(config)# aaa accounting exec default start-stop group radius
R(config)# aaa accounting commands 0 default start-stop group
radius
R(config)# aaa accounting commands 1 default start-stop group
radius
R(config)# aaa accounting commands 15 default start-stop group
radius
```

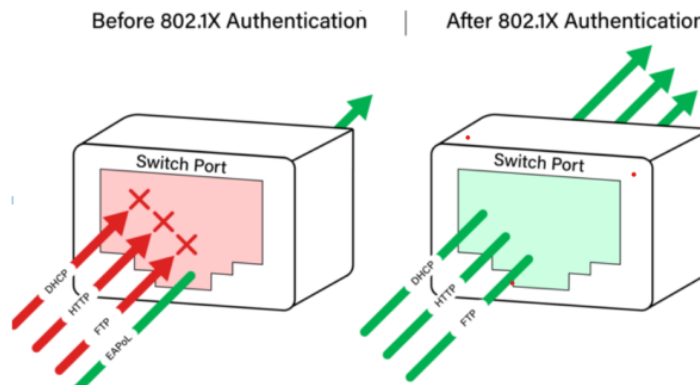
802.1X

La norme **IEEE 802.1X** est une norme de l'IEEE qui définit un mécanisme d'authentification pour le contrôle d'accès aux réseaux (LAN filaires et WLAN).



NAS - dans la terminologie RADIUS, le commutateur ou le point d'accès où se connecte le client. Il demande des informations d'identification au client et les transfère au serveur pour vérification. Il communique avec le serveur RADIUS via des trames EAP (encapsulation EAP Over RADIUS).

PAE : Port Access Entity - un port authentifié est « divisé » en deux ports : un qui laisse tout passer pour les trames d'authentification et l'autre qui ne laisse rien passer



États d'un port 802.1X :

authentication port-control { auto | forced-authorized | forced-unauthorized }

1. Auto

- Active l'authentification 802.1X.
- Par défaut → Unauthorized (seules trames EAP autorisées).
- Si authentification réussie → Authorized (trafic normal, VLAN attribué).
- Si déconnexion ou changement d'état du port → retour à Unauthorized.

2. Force-authorized

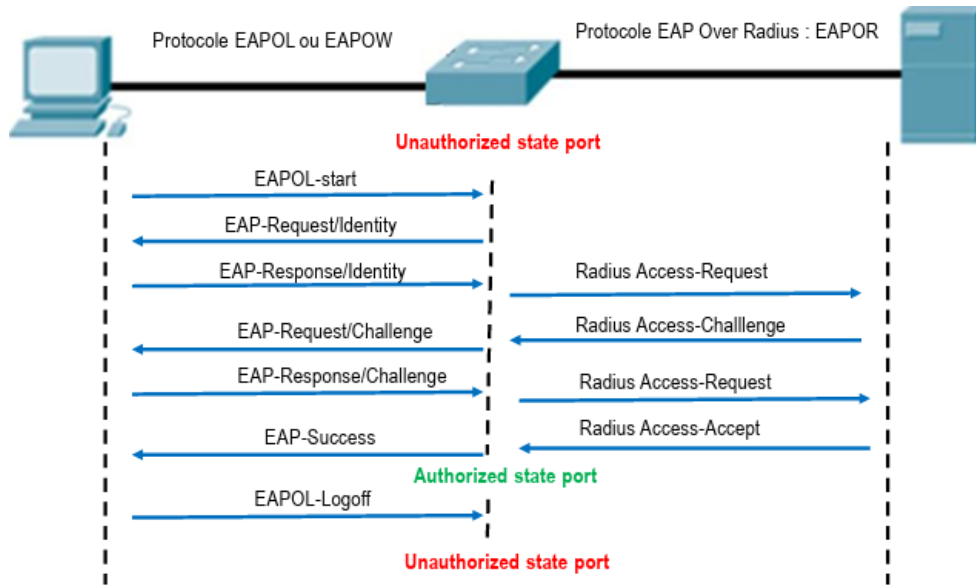
- Tout trafic est autorisé sans authentification 802.1X.
- État par défaut.

3. Force-unauthorized

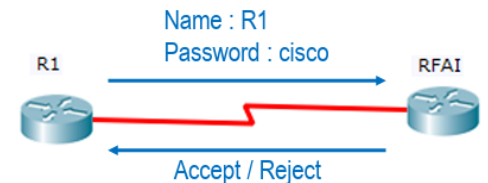
- Tout trafic est refusé.
- Aucune authentification possible pour autoriser le trafic.

Protocoles de transport

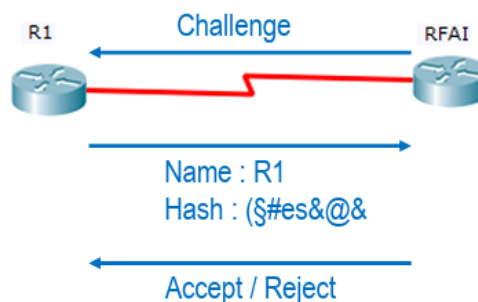
- **EAP (Extensible Authentication Protocol)** - «Protocole de transport» de protocoles d'authentification.



- Le **PAP (Password Authentication Protocol)** est un protocole d'authentification très simple et ancien défini dans la norme PPP (Point-to-Point Protocol). Mot de passe transmis en clair avec faible sécurité.



- **CHAP (Challenge Handshake Authentication Protocol)** - est un protocole d'authentification défini dans PPP (Point-to-Point Protocol), conçu pour être plus sûr que PAP. Il repose sur un mécanisme de challenge-réponse pour éviter d'envoyer le mot de passe en clair. L'authentification se fait par hachage et peut être répétée périodiquement.



RFAI → R1 : Challenge (ID + nombre aléatoire)

R1 → RFAI : Username + Hash(ID + mdp + aléa)

R2 : recalcul du hash

→ Accept ou Reject

- **MS-CHAPv2** – Microsoft a développé une variante qui ajoute une authentification mutuelle. Il y a authentification du serveur et authentification du client.
- **EAP/TLS** (Extensible Authentication Protocol – Transport Layer Security) - établit une session TLS avant d'échanger les infos. Client et serveur doivent posséder un certificat.

TLS ≠ mot de passe → on s'appuie sur des certificats numériques pour authentifier client et serveur.

- **EAP/PEAP (Protected EAP)**
 - Certificat serveur seulement.
 - Tunnel TLS → mot de passe transmis via MS-CHAPv2.
 - Bon compromis : simple à déployer, largement utilisé en entreprise.
- **EAP-TTLS (Tunneled Transport Layer Security)**
 - Certificat serveur seulement.
 - Tunnel TLS → méthodes flexibles (PAP, CHAP, MS-CHAPv2...).

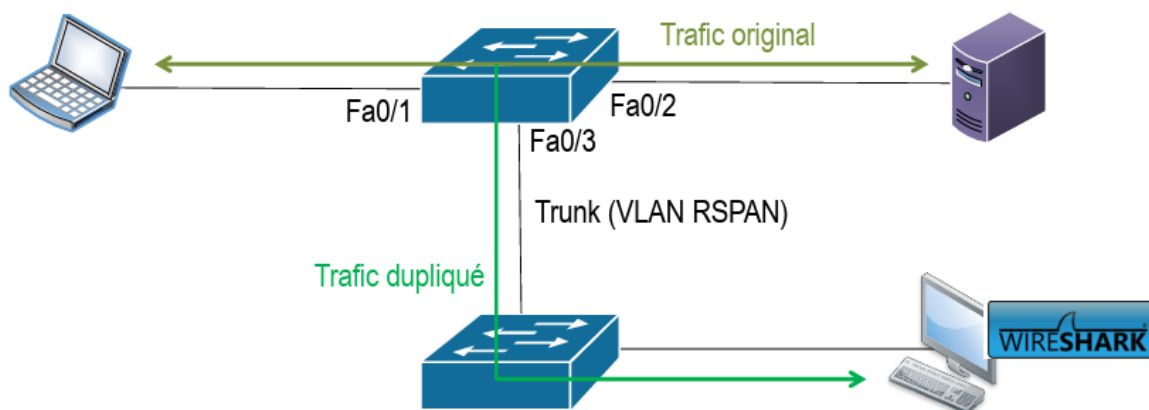
Configuration

- Activer globalement l'authentification 802.1X
`S(config)# dot1x system-auth-control`
- Activer AAA
`S(config)# aaa new-model`
- Spécifier l'utilisation de la méthode d'authentification 802.1X
`S(config)# aaa authentication dot1x {default} method1 ...`
`S(config)# aaa authentication dot1x default group radius`
- Activer l'authentification au niveau de l'interface
`S(config-if)# dot1x port-control auto`
- Activer l'authentification 802.1X avec les paramètres par défaut
`S(config-if)# dot1x pae authenticator` - **Port Access Entity** Authenticator : indique que l'interface du commutateur doit jouer le rôle de l'authentificateur.

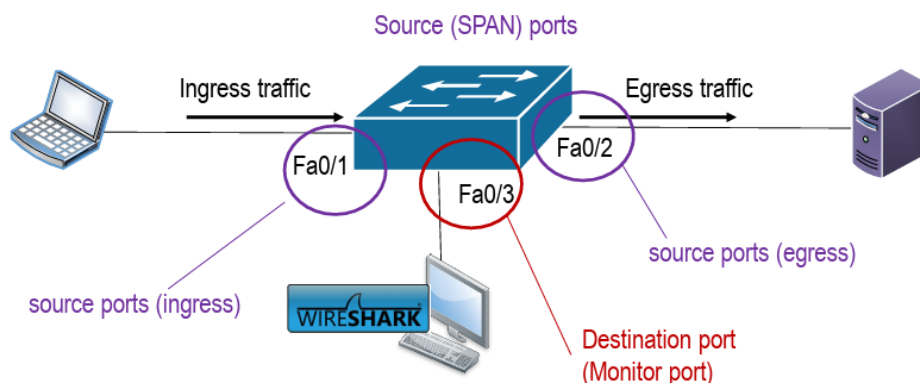
Port Mirroring

Le **Port Mirroring** est une fonctionnalité des switches administrables qui permet de copier le trafic réseau d'un ou plusieurs ports (ou VLANs) vers un port spécifique du switch. Le but : analyser le trafic sans perturber le réseau.

- **SPAN** (Switched Port Analyzer) – Terminologie Cisco.
- **VSPAN** (VLAN-based SPAN) : Permet de surveiller tous les ports qui appartiennent à un VLAN particulier en une seule commande.
- **RSPAN** (Remote SPAN) – les ports sources ne sont pas sur le même commutateur que le port destination.
 - RSPAN utilise deux sessions : une est utilisée comme source, l'autre sert à copier ou à recevoir le trafic d'un VLAN.
 - Le VLAN RSPAN doit être configuré dans tous les commutateurs participants. Le trafic de chaque session sera transporté vers ce VLAN en trunk.



- **Source port(s)** : le ou les ports (n'importe quelle couche et VLAN) dont il est possible de surveiller le trafic
- **Destination port (monitoring port)** : le port où l'on connecte un outil d'analyse (ex. Wireshark, IDS/IPS).
 - Seul le trafic surveillé transite par ce port.
 - Il ne participe pas à l'arborescence STP lorsque la session SPAN est active, le même pour VTP, CDP, DTP, PAgP.
 - Normalement un port participe qu'à une seule session à la fois, excepté sur certains modèles de commutateurs.



- **Session SPAN** est l'association entre un ou des ports source (ou VLAN source) et un ou des ports de destination.
 - Possède un numéro de session.

- Les sources d'une session SPAN peuvent être des ports ou des VLAN mais pas les deux à la fois.

Configuration

```
Sw(config)# monitor session number source [ interface interface-id | vlan vlan ] [ both | rx | tx ]
```

- rx (receive) – capture uniquement les paquets entrant sur l'interface (vers le switch).
- tx (transmit) - capture uniquement les paquets sortant de l'interface (du switch vers l'équipement).
- both - capture rx + tx.

```
Sw(config)# monitor session number destination [ interface interface-id | vlan vlan ]
```

```
Sw(config)# no monitor session {session_number | all | local | remote}
```

Exemple :

```
Sw(config)# monitor session 1 source interface fa0/2 both
```

```
Sw(config)# monitor session 1 destination interface fa0/3
```

Une copie de tout le trafic envoyé et reçu sur le port source Fa0/2 sera transmis au port de destination Fa0/3.

Créer le VLAN RSPAN:

```
Sw1(config)# vlan vlan-id
```

```
Sw1(config-vlan)# remote-span
```

```
Sw1(config)# monitor session number destination/source remote vlan-id]
```

(Virtual routing and forwarding)

- Le **VRF** est une technologie qui permet de créer plusieurs tables de routage indépendantes sur un même routeur ou switch de niveau 3.
- La table globale (**GRT**) - par défaut, toutes les interfaces IP l'utilisent. Lorsqu'une VRF est créée, elle dispose de sa propre table de routage, totalement isolée des autres VRF et de la GRT.
- Une interface peut appartenir à une et une seule VRF.
- Possible d'utiliser les mêmes IP dans les VRF différents.
- VRF-Lite = utilisation de VRF sans MPLS

Configuration

- Créer les VRF

```
Core1(config)# ip vrf CustA
Core1(config-vrf)# description VRF Client A
Core1(config)# ip vrf CustB
Core1(config-vrf)# description VRF Client B
```

- Activer IPv4 dans la VRF

```
Core1(config)# ip vrf CustA
Core1(config-vrf)# address-family ipv4
```

- Assigner une interface à une VRF

```
Core1(config)# interface GigabitEthernet0/1
Core1(config-if)# ip vrf forwarding CustA
Core1(config-if)# ip address 10.254.254.1 255.255.255.252
```

```
Core1#show ip vrf
Name      Default RD      Interfaces
CustA     <not set>       Gi0/1
                               Fa0.12
                               Fa0.11
CustB     <not set>       Gi0/2
```

Route Distinguisher (RD) – est un identifiant unique de la route

- Créer une route statique dans une VRF

```
Core1(config)# ip route vrf CustA 10.10.0.0 255.255.255.0 10.254.254.2
```

- Après la configuration des VRF `ip route` sera vide, pour afficher les tables de routage des VRF :

```
Core1(config)# show ip route vrf CustA
```

- Utiliser les routes de la GRT :

```
Core1(config)# ip route vrf CustA 192.168.2.0 255.255.255.0 204.12.8.1 global
```

global signifie : « le next-hop 204.12.8.1 est atteignable via la table de routage globale, pas via la VRF CustA ». GRT doit avoir une route valide vers 204.12.8.1

Attention : on peut perdre l'isolation entre ces réseaux

Qualité de service

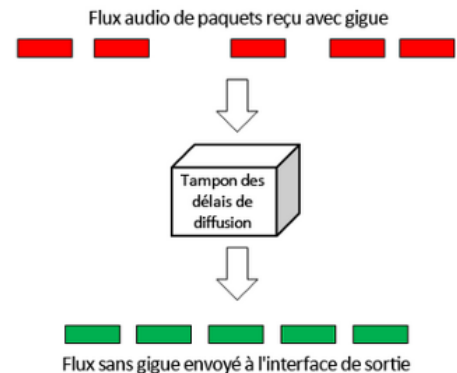
Caractéristiques de différent trafic

La **gigue** est une irrégularité dans la réception. Ex :

- Voix coupée ou hachée dans un appel.
- Image figée ou saccadée dans une visioconférence.

Tampon des délais de diffusion

- Mécanisme qui tente de compenser la gigue
- Si la gigue est trop importante, des paquets peuvent être perdus.
- Si un seul paquet est perdu, les DSP peuvent réaliser une interpolation et rendre la perte du paquet inaudible.



Caractéristiques du trafic "voix" :

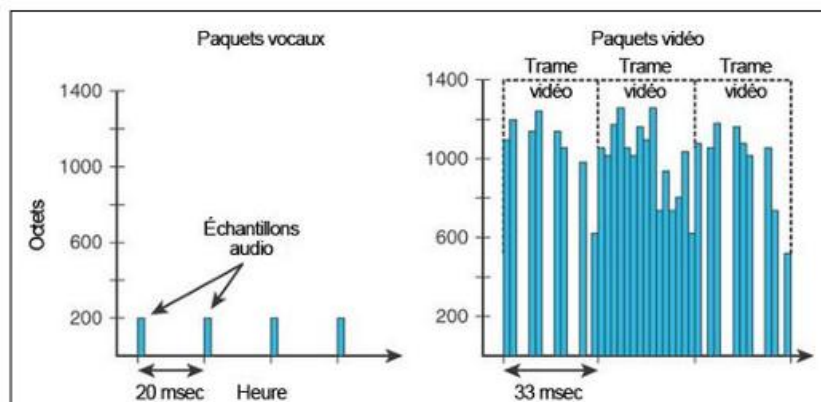
- Le trafic voix utilise peu de ressources réseau (Minimum 30Kbits/s de BP).
- Le trafic est fluide et régulier, les paquets de voix arrivent toutes les 20ms et ont toujours la même taille de 200 octets.



- Trafic très sensible aux délais - la latence ne peut pas dépasser 150ms et la gigue 30ms.
- Il est impossible de retransmettre le trafic perdu.
- La perte de paquets de voix doit être inférieure à 1%.

Caractéristiques du trafic Vidéo :

- Le trafic vidéo est imprévisible
- Le nombre et la taille des paquets vidéo varient toutes les 33ms selon le contenu de la vidéo
- Un contenu qui change beaucoup et rapidement (scène d'action) va générer des paquets vidéo plus volumineux et en plus grande quantité.
- Nécessite une BP de minimum 384Kbits/s.
- La latence ne peut pas dépasser 400ms et la gigue 50ms. La perte de paquets vidéo doit être < à 1%.



En sachant que le trafic des données n'est pas aussi sensible (car les applications continuent de fonctionner, même si parfois il faut attendre un peu, ou réessayer) il existe des techniques de QoS pour ce type de trafic.

La mise en file d'attente

(Ordonnancement, scheduling)

Algorithmes de mise en file d'attente

Recommandés pour les réseaux actuels
(multimédias) :

- CBWFQ : Class-Based Weighted Fair Queuing.
- LLQ : Low Latency Queuing.

Anciens algorithmes :

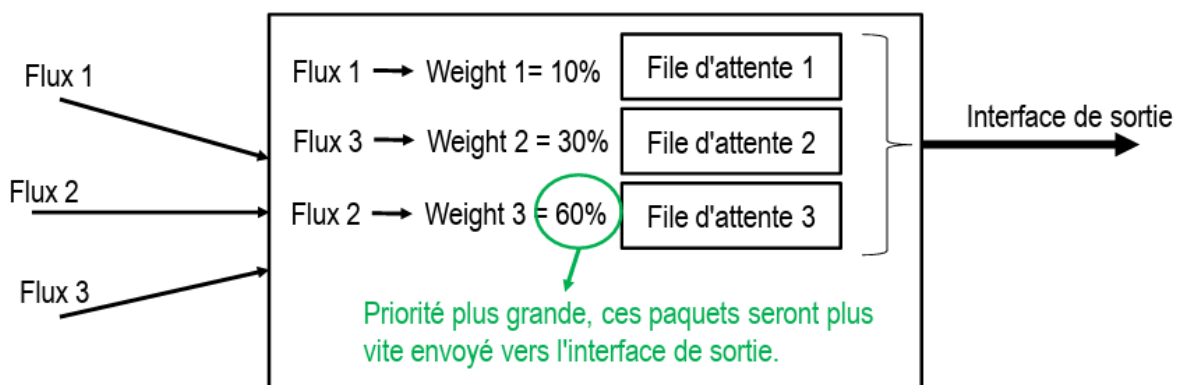
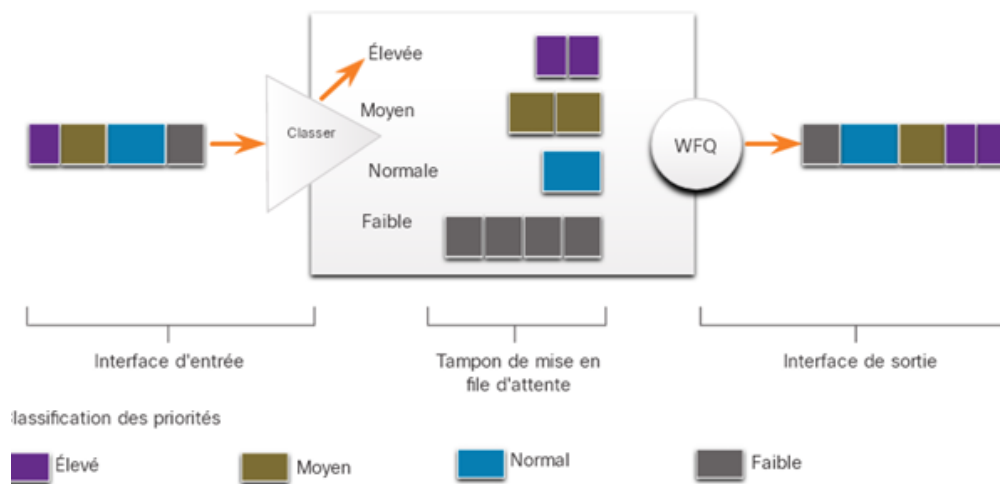
- FIFO : First-In, First-Out, (Weighted) Round Robin, Custom Queuing, Priority Queuing, WFQ : Weighted Fair Queuing.

FIFO (First-In, First-Out) – la méthode la plus rapide, une seule file d'attente. Pas de priorisation des paquets possible.

Weighted Fair Queuing (WFQ) - mise en file d'attente pondérée.

Chaque file reçoit une portion du débit en fonction de son poids.

WFQ va utiliser plusieurs files d'attentes et prendre un paquet dans chaque file.



Si le flux 2 est terminé, le pourcentage est recalculé dynamiquement.

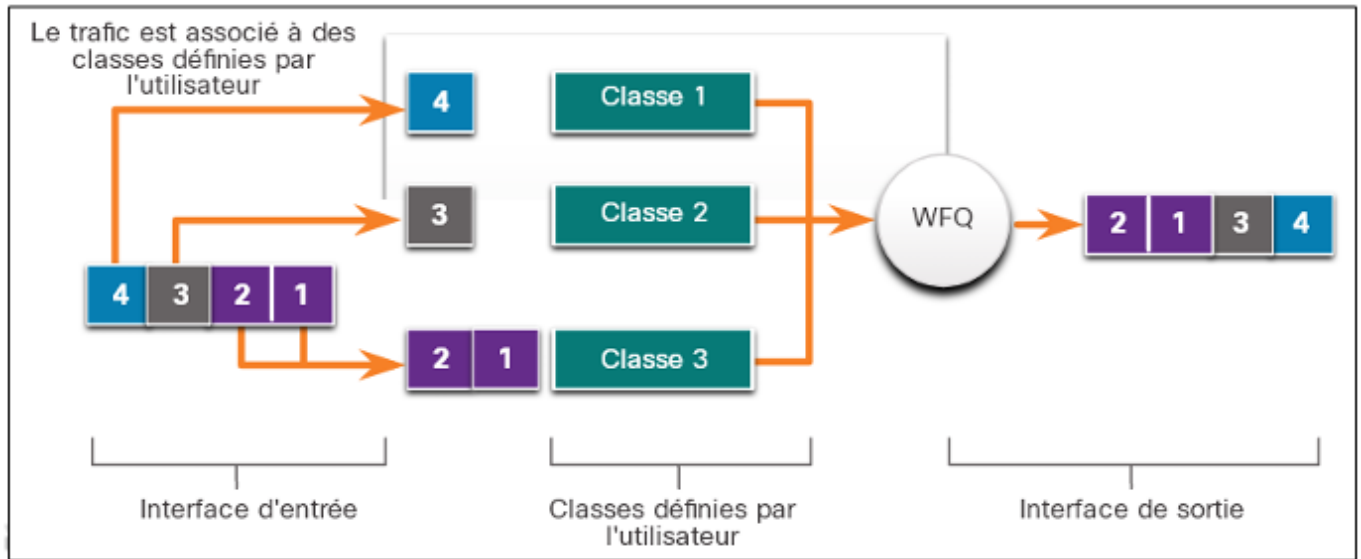
Part du flux = (poids du flux / somme des poids actifs) × 100 %

Flux 1 aura $10/40 \times 100\% = 25\%$

Flux 3 aura $30/40 \times 100\% = 75\%$

Class-Based Weighted Fair Queuing (CBWFQ) - Mise en file d'attente pondérée basée sur les classes

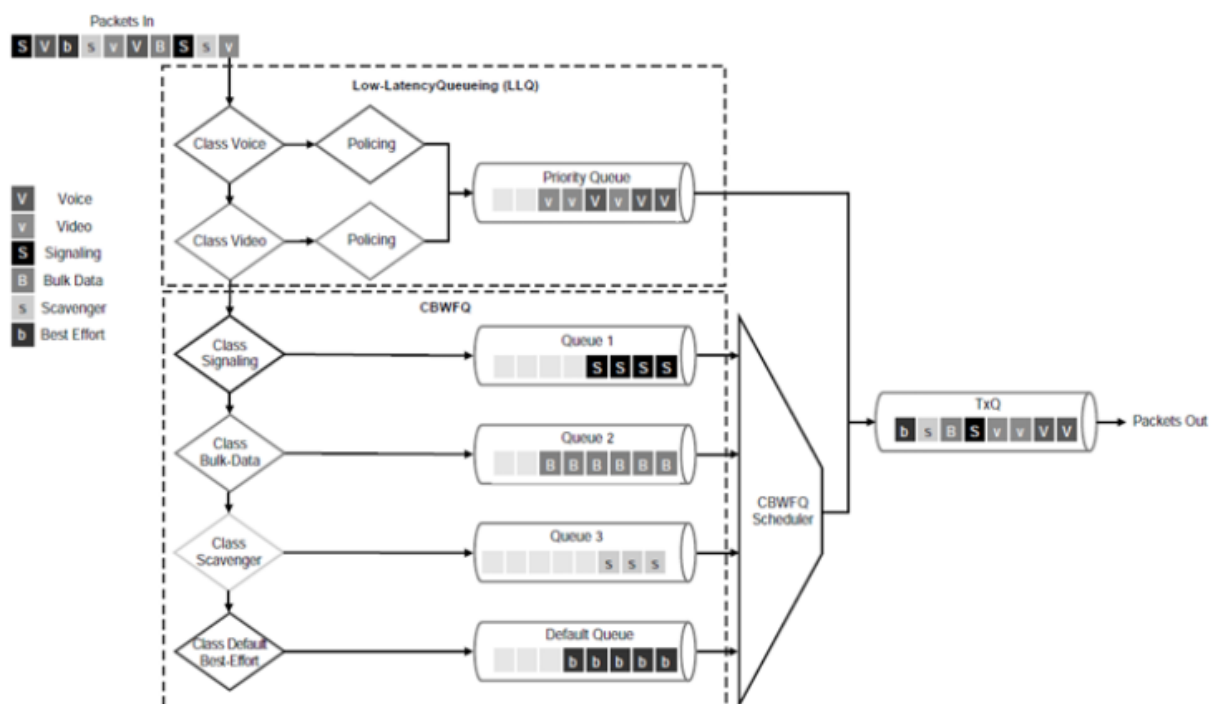
Une file d'attente FIFO est réservée à chaque classe. Permet de créer jusqu'à 256 files d'attente, desservant jusqu'à 256 classes de trafic.



L'administrateur peut attribuer des caractéristiques aux classes :

- La quantité de bande passante garantie pour la classe.
- Attribuer un poids.
- Fixer une limite maximale de paquets (Limite de la file d'attente). Si la file d'attente d'une classe est remplie, les paquets suivants de cette classe sont perdus.

Low Latency Queuing (LLQ) - Combine CBWFQ avec une file prioritaire stricte pour la voix ou les flux temps réel



Modèles d'implémentation QoS

1. Best-effort

- Aucun mécanisme QoS : tout le trafic est traité de la même manière.
- Pas de garantie de bande passante, délai ou livraison.
- Utilisé pour des applications non sensibles (ex. : navigation web, e-mails).

2. Services intégrés (IntServ)

- Réservation explicite des ressources pour chaque flux (via Resource Reservation Protocol RSVP).
- Qualité de service garantie de bout en bout.
- Très précis mais lourd et peu scalable, car trop de signalisation.

3. Services différenciés (DiffServ)

- Les paquets sont classifiés.
- Chaque routeur applique des règles spécifiques (priorités, files, etc.).
- Flexible et scalable, convient bien aux réseaux d'entreprise ou FAI.

Prévention de la congestion

Les applications TCP s'adaptent automatiquement à l'encombrement (Ralentissement via le fenêtrage).

RED(Random Early Detection) est un mécanisme de gestion de la congestion dans les routeurs et switchs. Il est conçu pour éviter que les files d'attente des paquets ne débordent brutalement, ce qui causerait des pertes massives de paquets. Supprime les paquets non prioritaires avant qu'il n'y ait encombrement

WRED (Weighted Random Early Detection) est une extension intelligente de RED, utilisée principalement dans les réseaux IP avec qualité de service (QoS) car il sait différencier les paquets prioritaires. Ne fonctionne pas pour UDP.

Outils de classification (analyse) et marquage (ajout d'en-tête)

Classification – consiste à classer un paquet dans un groupe spécifique (pour un traitement QoS)

- **Couche 2 (liaison)**

Basée sur les interfaces physiques ou VLANs. Utilise 802.1p (priorité dans l'en-tête 802.1Q).

- **Couche 3 (réseau)**

Utilise des ACL ou des class-maps pour filtrer par IP, protocole, etc.

```
R1(config)#access-list 101 permit ip any any ?
    dscp      Match packets with given dscp value
    precedence Match packets with given precedence value
    <cr>
```

- **Couches 4 à 7 (transport à application)**

Utilise la fonction **NBAR (Network-Based Application Recognition)** – propriétaire Cisco.

Permet de reconnaître les applications (ex : Skype, Teams, YouTube) non seulement par port, mais aussi par signature.

Les signatures sont téléchargeables depuis Cisco pour mettre à jour la reconnaissance.

Marquage - consiste à ajouter une valeur à l'en-tête du paquet.

Le marquage doit être effectué le plus près possible du périphérique source.

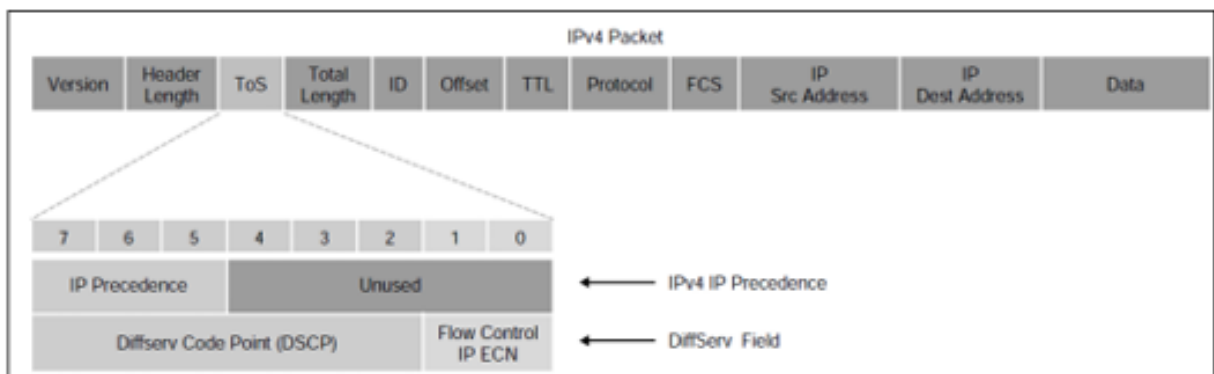
- **Couche 2** est possible pour le trafic non IP, est la seule option QoS possible pour les commutateurs qui ne reconnaissent pas IP (L2).

Outils QoS	Couche OSI	Champ de marquage
Ethernet (802.1Q, 802.1p)	2	Class of service (Cos)
Wi-Fi (802.11)	2	Traffic Identifier (TID)
MPLS experimental values	2	EXP
IPv4 et IPv6	3	IP Precedence (IPP), Explicit Congestion Notification (ECN)
IPv4 et IPv6	3	Differentiated Services Code Point (DSCP)

Marquage **TCI (Tag Control Information)** est codé sur 16 bits dans l'en-tête 802.1Q VLAN, dont 3 bits (PRI) réservés pour la QoS

Valeurs Cos et IPP	
Valeur	Description
6 et 7	Généralement réservé au trafic de contrôle réseau (protocoles de routage)
5	Recommandé pour la voix
4	Recommandé pour la vidéoconférence et le streaming
3	Recommandé pour la signalisation d'appel voix
2	Trafic de données à priorité forte
1	Trafic de données à priorité moyenne
0	Trafic de données à priorité faible (best effort = valeur par défaut)

- **Couche 3** – Permet de transporter les informations QoS de bout en bout.
 - Utilise un champ de 8 bits dans les paquets IPv4 et IPv6. «Type of service» pour IPv4 et «Traffic Class» pour IPv6
 - 2 bits IP ECN (Explicit Congestion Notification) – signale le début de congestion
 - 6 bits DSCP utilisés par DiffServ pour le marquage. Offre 64 possibilités de marquage.



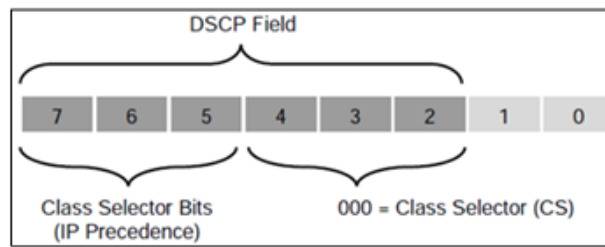
Traitement des paquets

- **PHB (Per-Hop Behavior)**

Le PHB est un comportement de traitement des paquets au niveau de chaque nœud réseau (chaque "hop", c'est-à-dire switch ou routeur), défini par la valeur DSCP dans l'en-tête IP. A chaque saut, les paquets sont «accélérés», retardés ou abandonnés en fonction de la valeur DSCP.

4 PHB ont été définis:

- **Class SelectorBHP** - Utilisé pour la rétrocompatibilité avec les périphériques non conformes à DiffServ, compatible avec IP



- **Default Forwarding (DF) PHB** - DF PHB et CS0 offrent un service au mieux (Best effort), ne peut pas être classé par un mécanisme de QoS.
- **Assured Forwarding (AF) PHB** - garantit une certaine quantité de BP à une classe de trafic AF

AF Class Name	AF IP Procedure Dec (x)	AF IP Procedure Bin	Drop Probability	Drop Probability Value Bin	Drop Probability Value Dec (y)	AF Name (Afxy)	DSCP Value Bin	DSCP Value Dec
AF1	1	001	Low	01	1	AF11	001010	10
AF1	1	001	Medium	10	2	AF12	001100	12
AF1	1	001	High	11	3	AF13	001110	14
AF2	2	010	Low	01	1	AF21	010010	18
AF2	2	010	Medium	10	2	AF22	010100	20
AF2	2	010	High	11	3	AF23	010110	22
AF3	3	011	Low	01	1	AF31	011010	26
AF3	3	011	Medium	10	2	AF32	011100	28
AF3	3	011	High	11	3	AF33	011110	30
AF4	4	100	Low	01	1	AF41	100010	34
AF4	4	100	Medium	10	2	AF42	100100	36
AF4	4	100	High	11	3	AF43	100110	38

Valeurs « Drop probability » sont utilisées par le WRED. En cas de congestion entre les classes, le trafic de la classe supérieure est prioritaire.

- **Expedited Forwarding (EF) PHB** - Traitement accéléré des paquets, une garantie de bande passante ainsi qu'une perte, une latence et une gigue faibles -> intéressant pour VoIP
Bits DSCP 5 à 7 = 101xxx
- **Scavenger Class - CS1** - trafic moins prioritaire qu'un service «best-effort». Par ex. pour marquer les applications de jeu, YouTube Netflix etc
- **Traffic Shaping** - Lisser le trafic pour éviter les pics en retenant temporairement les paquets. Agit uniquement sur le trafic sortant, associé à CBWFQ LLQ. Utilisé en sortie des interfaces WAN ou vers un fournisseur d'accès.
- **Limitation (Traffic Policing)** - Faire respecter un débit maximum autorisé, en supprimant ou re-marquage le trafic excédentaire avec une priorité inférieure.
Peut être appliquée sur le trafic entrant ou sortant. **Algorithmes** :

Single-rate Two-Color Marker

Évalue si le débit est en-dessous ou au-dessus d'un seul seuil.

**Single-rate Three-Color
Marker (srTCM)**
**Two-rate Three-Color
Marker (trTCM)**

Classe les paquets en vert, jaune, ou rouge, selon un débit max + tolérance.
Utilise deux seuils de débit : un débit moyen + un débit de pointe.

Frontières de confiance (trust boundary)

L'endroit du marquage des paquets permet de définir la frontière de confiance.

Les équipements comme les PC, téléphones IP ou applications peuvent marquer eux-mêmes les paquets avec des valeurs DSCP ou CoS élevées pour obtenir un meilleur traitement.

Sans contrôle, un utilisateur malveillant ou mal configuré peut :

- Marquer tous ses paquets avec la priorité la plus haute,
- Et ainsi saturer les files prioritaires, nuisant aux vrais flux critiques (VoIP, etc.).

Que faire à la frontière ?

1. Vérifier les marquages entrants (CoS, DSCP, ToS...)
2. Selon la politique :
 - Accepter les valeurs (si le périphérique est de confiance)
 - Réinitialiser ou re-marquer les paquets (si non fiable)

Appliquer des politiques QoS (limitation, priorité...) **Pourquoi comptabiliser?**

- Pour facturer l'utilisation de ressources.
- Les utilisateurs étant "surveillés", ils font plus attention.
- Pour détecter des actions suspectes voir interdites.
- Pour mieux cibler la source d'un problème et intervenir.
- Pour avoir une trace légale des actions effectuées sur un système de l'entreprise.

Comptabiliser quoi?

- Les commandes exécutées.
- Les temps de connexion.
- Le volume de données (nombres d'octets transmis).
- Les informations sur les connexions Telnet ou SSH (qui, quand, ...).
- Les événements systèmes (lorsque le système redémarre par exemple).

-

Pentesting

Les systèmes de détection

IDS – Intrusion Detection System

- Analyse le trafic réseau ou les événements systèmes et génère des alertes.
- Aucune action directe sur le trafic.

IPS – Intrusion Prevention System

- Détecte et bloque les attaques en temps réel.

IDPS – Intrusion Detection and Prevention System

- combinaison IDS + IPS.

Phase 1 : Pre-engagement interactions

Phase de définition des accords contractuels et financiers, doit être validé par le client et le prestataire.

Exemples de **réglementations** auxquelles certaines entreprises doivent se conformer :

- Protection des données
RGPD : Règlement général sur la protection des données (Europe).
- Réglementation dans le secteur financier
GLBA : Gramm-Leach-Bliley Act (États-Unis).
- Réglementation dans le secteur des soins de santé
HIPAA : Health Insurance Portability and Accountability Act (États-Unis).
- Réglementation relative aux cartes de paiement.
PCI-DSS : Payment Card Industry Data Security Standard

Types de pentest en fonction des connaissances du prestataire :

Unknown-environment testing (Black box) : le testeur n'a aucune info sur la cible, comme un attaquant externe.

- **Avantages** : réaliste, rapide, moins coûteux, peut surprendre l'équipe défensive.
- **Inconvénients** : moins exhaustif, ne permet pas de vérifier la configuration interne des systèmes.

Known-environment testing (White box) : le testeur a un maximum d'informations (topologie, identifiants, configs, code source, etc.).

- **Avantages** : analyse approfondie, détection d'un grand nombre de failles.
- **Contexte** : simulation d'un administrateur interne.
- **Contraintes** : exige des compétences élevées du pentester.

Partially known environment testing (Grey box) : le testeur dispose d'informations limitées (ex. accès à un poste client avec identifiants valides).

- **Avantages** : reflète le scénario d'un utilisateur interne compromis ou malveillant.
- **Contexte** : approche hybride entre black box et white box.
- **Objectif** : évaluer les risques liés à un compte standard à l'intérieur du réseau.

Phase 2 : Intelligence Gathering

Consiste à rassembler un maximum d'informations sur les cibles. On parle de reconnaissance, footprinting ou information gathering.

Reconnaitssances par des méthodes passives :

- **Reconnaissance passive** : collecte d'informations publiques sans interagir avec la cible (réseaux sociaux, WHOIS, DNS). Discrète mais limitée.
- **Reconnaissance semi-passive** : interaction légère imitant un usage normal (naviguer sur le site, tester l'appli) sans scans intrusifs.
- **Reconnaissance active** : interaction directe avec la cible (scan de ports, scan de vulnérabilités). Plus riche en infos mais détectable par la défense.

Les informations utiles en reconnaissance :

- **Sécurité physique** : caméras, capteurs, clôtures, entrées, agences secondaires moins sécurisées.
- **Relations de l'entreprise** : partenaires, fournisseurs, clients → exploitables pour l'ingénierie sociale ou comme points d'entrée indirects.
- **Dates importantes** : réunions, vacances, événements → périodes où la défense est affaiblie.
- **Offres d'emploi** : révèlent les technologies et systèmes utilisés en interne.
- **Employés** : organigramme, postes, interactions, identifiants (emails, numéros, logins).
- **Réseaux sociaux** : localisation, technologies, projets, événements.
- **Métadonnées** : auteur, date, localisation réseau, géolocalisation, logiciel utilisé.
- **Réseaux techniques** : IP, Wi-Fi, protocoles et normes de sécurité.
- **Contre-mesures** : pare-feu, antivirus, WAF, proxy.

Des outils passifs / semi-passifs de reconnaissance :

- **Recherche de domaines et DNS** :
 - *Classiques* : DNSdumpster, Dnsrecon, host, dig, nslookup, tracert, WHOIS.
 - *Modernes* : Amass, Sublist3r, SecurityTrails, Censys, Shodan.
- **Métadonnées dans les documents** :
 - *Classiques* : FOCA, Exiftool, meta-extractor.
 - *Modernes* : Metagoofil, ExifProbe, OSINT Combine Metadata Extractor.
- **Localisation via réseaux sociaux** :
 - *Classiques* : Bing Maps, Foursquare, Google Latitude, Yelp.
 - *Modernes* : Instagram geotags, Twitter Advanced Search, LinkedIn Sales Navigator, OSINTgram.
- **Adresses email** :
 - *Classiques* : extraction sur sites, forums, blogs.
 - *Modernes* : Hunter.io, theHarvester, EmailHippo, Clearbit.
- **Outils divers de reconnaissance large** :
 - *Classiques* : Spiderfoot, Recon-ng.
 - *Modernes* : Maltego, Shodan, FOFA, GreyNoise, IntelligenceX.

Exemple d'outils de reconnaissance active :

- **Scanner de ports**
 - Nmap, zenmap, masscan...
- **Scanner de vulnérabilités**
 - Nessus, OpenVAS, Qualys...
 - Dans PTES, l'utilisation d'un scanner de vulnérabilité peut aussi être reprise dans la phase 3 : vulnerability analysis.
- **Scanner de services Web**

- Nikto.
- BurpSuite.

Scan du réseau

Network scanning - processus permettant de découvrir les périphériques actifs d'un réseau ainsi que fournir des informations sur ces périphériques.

Les scanners font du «bruit», peuvent être détectés.

Scan furtif (StealthScans) - options moins «bruyantes». Par exemple, un SYN scan est moins bruyant qu'un Connect scan.

Exemple d'informations pouvant être récoltées :

- **Cartographie du réseau** (Network mapping) : Envoi de messages sur l'ensemble du réseau afin d'obtenir une réponse et ainsi découvrir des hôtes actifs.
- **Port/services actifs** (Port scanning) : Envoi de messages à des ports TCP/UDP afin de déterminer s'ils sont actifs.
- **Détection de service** : Envoi de messages à un port afin de générer des réponses qui permettront de déterminer le type et la version du service en cours d'exécution.
- **Détection du système d'exploitation** : Envoi de messages à un hôte afin de générer des réponses qui permettront de déterminer le système d'exploitation.
- **Détection des vulnérabilités connues** : Nmap comprend une suite de scripts (Nmap Scripting Engine, NSE) qui comparent les versions des services découverts avec la base de données CVE.

Connect (`nmap -sT 192.168.0.1`) - une connexion TCP complète.

Réponse de la cible	Status bmap du port	Analyse
TCP SYN/ACK	Open	Le service écoute sur ce port
TCP RST	Closed	Le service n'écoute pas sur ce port
Pas de réponse	Filtered	Le port est filtré (pare-feu)

Découverte par ICMP

- **ICMP Echo (icmp type 8)** : ping classique pour identifier les hôtes actifs (ping sweep).
- **ICMP Timestamp (type 13)** : l'hôte renvoie l'heure système.
- **ICMP Address Mask (type 17)** : l'hôte renvoie son masque réseau.

Limite : de nombreux hôtes bloquent ICMP.

ICMP type 8 : `# nmap -PE 192.168.0.1`

ICMP type 13 : `# nmap -PP 192.168.0.1`

ICMP type 17 : `# nmap -PM 192.168.0.1`

Découverte via TCP

- **TCP SYN (-PS)** : envoi d'un TCP SYN (vide) vers un port (80 par défaut). Rapide, relativement furtif. Ne complète pas la connexion TCP comme -sT.
- **TCP FIN (-sF)** : FIN envoyé, absence de réponse → port probablement ouvert, réponse RST → port fermé. Plus furtif que SYN, non fiable sur Windows (répondent par des RST, quel que soit l'état du port).
- **TCP ACK (-sA)** : permet de distinguer hôtes filtrés / non filtrés, ne permet pas de voir les ports sont ouverts ou fermés.

S'il n'y a pas de filtrage les ports ouverts et fermés renverront un paquet RST.

S'il y a un filtrage, soit le scanner ne recevra rien, soit il recevra un message d'erreur ICMP (Type 3 : Destination unreachable, code 1, 2, 3, 9, 10, ou 13)

Type	Code	Description
3 – Destination Unreachable	0	Destination network unreachable
	1	Destination host unreachable
	2	Destination protocol unreachable
	3	Destination port unreachable
	4	Fragmentation needed and DF flag set
	5	Source route failed
...	...	...

- **Ping scan (-sP)** : combinaison ICMP + TCP pour détecter les hôtes actifs.

Découverte via UDP

- **UDP scan (-PU / -sU)** : envoi de paquets UDP aux ports UDP. Obtient les réponses ICMP.
- Ports fermés → ICMP unreachable.
- Pas de réponse → port open | filtered.
Lent et peu fiable sans charge utile spécifique.

Probe Response	Assigned State
Any UDP response from target port (unusual)	open
No response received (even after retransmissions)	open filtered
ICMP port unreachable error (type 3, code 3)	closed
Other ICMP unreachable errors (type 3, code 1, 2, 9, 10, or 13)	filtered

IP Protocol Ping

- **IP protocol scan (-PO)** : envoi de paquets IP avec différents numéros de protocole (ICMP 1, TCP 6, UDP 17...).
- Toute réponse indique un hôte actif.
Peut échouer si filtrage ICMP ou firewall.

ARP Scan

- **ARP scan (-PR)** : envoi direct de requêtes ARP sur le réseau local.
- Très fiable et rapide en LAN, nmap gère lui-même le temps d'attente des requêtes ARP.
- Si réponse ARP → hôte actif (ICMP inutile).

Discovery Scan global

- Avec l'option **-sn**, nmap envoie
 - une demande d'écho ICMP (ping),
 - un SYN TCP au port 443,
 - un ACK TCP au port 80
 - et une demande d'horodatage ICMP (icmp timestamp).

Options de temporisation

- **-T0 à -T5** : contrôle la vitesse du scan.
T0-T1 : très lent, furtif (évasion IDS).
T3 : normal (par défaut).
T4-T5 : rapide/agressif, détectable.

Autres options courantes de Nmap :

- **-v / -vv (verbose)** : affiche plus d'informations pendant le scan, y compris les hôtes inactifs.
- **--reason** : indique la raison exacte pour laquelle un hôte ou port est marqué (réponse reçue).
- **--data-length <n>** : ajoute des données aux paquets pour éviter les alertes IDPS ; 32 octets simule Windows, 56 Linux.
- **--exclude / --excludefile** : exclut des hôtes ou des listes d'hôtes du scan.
- **-n** : désactive la résolution DNS pour accélérer le scan.
- **-6** : force l'utilisation d'IPv6.

Active fingerprinting

Nmap tente d'identifier le fabricant, l'OS, la version de l'OS, le type de périphérique. Analyse via les piles et configurations TCP/IP, pour chaque OS c'est différent.

```
# nmap -O 192.168.0.1
```

Récapitulatif des états de ports

État du port	Signification	Comportement observé	Remarques
Open (ouvert)	Un service écoute sur le port	Réponse valide TCP/UDP	Cible prioritaire pour les attaques
Closed (fermé)	Port accessible mais aucun service	Réponse RST / ICMP	Indique que l'hôte est actif
Filtered (filtré)	Accès bloqué par un dispositif de sécurité	Aucune réponse ou ICMP unreachable (type 3 code 13)	Impossible de déterminer l'état réel
Unfiltered (non filtré)	Port accessible mais état inconnu	Réponse reçue (ACK scan)	Utilisé uniquement avec le scan ACK
Open filtered	Ouvert ou filtré (indéterminé)	Aucune réponse	Typique des scans UDP
Closed filtered	Fermé ou filtré (indéterminé)	Pas de réponse claire	Utilisé uniquement avec le scan Idle

Formats de sortie Nmap :

- **Interactive (par défaut)** : résultats affichés directement à l'écran.
- **Normal (-oN)** : sortie texte enregistrée avec moins de détails.
- **XML (-oX)** : sortie structurée en XML, exploitable par d'autres outils.
- **Grepable (-oG)** : format simple (déprécié), une ligne par hôte, facile à analyser par scripts (grep etc).

Scan Idle

Le scan Idle est une technique de scan très furtive qui permet d'analyser les ports d'une cible sans jamais la contacter directement, en utilisant une machine intermédiaire appelée zombie.

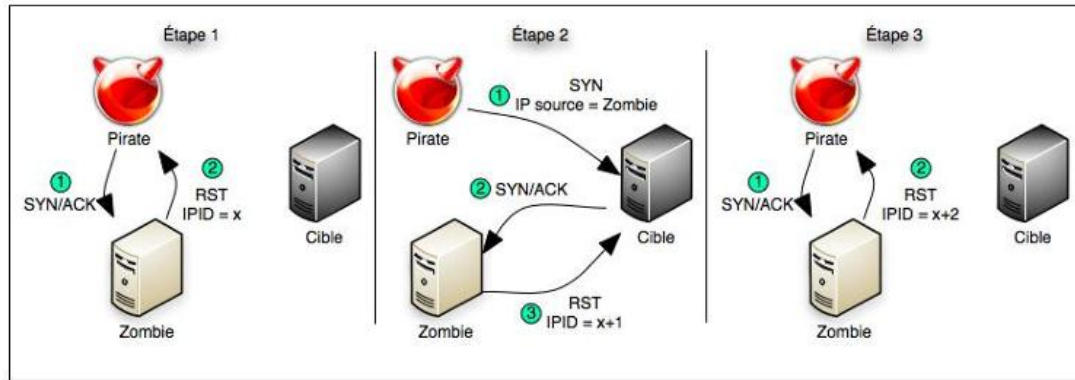
Il exploite le champ IP ID de l'en-tête IP.

Le champ (**IP ID**) peut être généré de plusieurs façons :

- **Compteur global** : incrémenté de 1 à chaque paquet envoyé.
- **Compteur local** : incrémentation dépendante de la destination.
- **Pseudo-aléatoire** : valeur imprévisible (cas le plus courant aujourd'hui).
- **Constant** : souvent 0.

Le scan Idle ne fonctionne que si l'IP ID est prévisible et incrémental.

1. Le pirate interroge le **zombie** et observe son IP ID (valeur X).
2. Il envoie un paquet à la **cible** en usurpant l'IP du zombie.
3. Selon l'état du port sur la cible :
 - **Port ouvert** → la cible répond au zombie → le zombie envoie un RST → IP ID augmente de 2.
 - **Port fermé** → la cible envoie un RST au zombie → IP ID augmente de 1.
4. Le pirate réinterroge le zombie et déduit l'état du port en comparant les IP ID.



Phase 3 : Threat Modeling (Modélisation des menaces)

Consiste à identifier, analyser et prioriser les menaces qui peuvent affecter un système avant ou pendant sa mise en production.

Exemple : DB SQL → il existe attaque par injection SQL → Web application Firewall

Les actifs sont tout ce qui a de la valeur pour une organisation et qui doit être protégé, ex : données clients, serveurs, employés, réputation etc.

Acteurs des menaces : cybercriminels, hacktivistes etc.

Capacités de la menace - capacité à obtenir ou à développer des exploits pour l'environnement de l'organisation pour chaque acteur.

MITRE ATT&CK® (Adversarial Tactics, Techniques, and Common Knowledge) - organise et catégorise divers types de tactiques, techniques et procédures (TTP) utilisées par les acteurs de la menace.

Phase 4 : Vulnerability Analysis (Analyse des vulnérabilités)

Analyse des informations récoltées dans la phase de collecte pour identifier des vulnérabilités.

Exemples d'analyse :

- En mettant en corrélation les numéros de version des OS ou des applications avec les vulnérabilités connues (CVE).
- En analysant le code source de programmes

Phase 5 : Exploitation

Choisir et mettre en œuvre les attaques contre les vulnérabilités identifiées.

Pour l'injection SQL par ex. : Créations de commandes d'injections SQL pour tenter de se connecter sans mot de passe et récupérer des informations de la base de données.

Phase 6 : Post-exploitation

Consiste à maintenir un accès permanent sans devoir répéter l'attaque initiale et à effacer les traces.

On peut installer des backdoors, créer un compte user caché, désactiver les systèmes de protection etc.

Bind shell

Un attaquant ouvre un port et un service qui écoute sur le système compromis et se connecte dessus.

Reverse shell

La victime établit une connexion avec le système attaquant qui dispose d'un service en écoute sur un port déterminé.

Avantage : contourne souvent les pare-feux, car la connexion sortante est autorisée

Le **Command and Control (C2, CnC, C&C)** est l'infrastructure utilisée par un attaquant pour communiquer avec des machines compromises et les contrôler à distance.

Privilege Escalation (Élévation de privilège) – permet à un utilisateur d'obtenir des privilèges supérieurs à ceux qu'il a normalement.

- Escalade verticale des privilèges – moins → plus
- Escalade horizontale des privilèges – un user accède à des fonctions ou au contenu réservé à d'autres users non-root.

Buffer overflow – attaquant cible un programme qui s'exécute en root sur Linux, le buffer déborde et écrase le return address, attaquant change le pointeur vers le code malveillant.

Pivoting – le mouvement latéral, consiste à utiliser une machine compromise comme point d'accès pour explorer ou attaquer d'autres systèmes dans un réseau. Plus facile si le réseau n'est pas segmenté.

Exfiltration des données - l'acte de déplacer des données sensibles de l'intérieur d'une organisation vers l'extérieur sans autorisation. Utilise les tunnels chiffrés, stéganographie (cacher les données dans une image).

Pass-the-Hash (PtH) - utiliser directement le hash du mot de passe d'un utilisateur pour s'authentifier, sans connaître le mot de passe en clair.

Pass-the-Ticket (PtT) - consiste à voler et réutiliser un ticket Kerberos valide pour s'authentifier.

Payloads - codes qui s'exécutent sur une machine cible après une exploitation réussie.

- **Singles** : payloads autonomes, une seule action simple.
- **Stagers** : petits payloads initiaux qui établissent la connexion avec l'attaquant et téléchargent la suite.
- **Stages** : payloads complets et avancés (session interactive, scripts complexes)
- **Adapters** : permettent de chaîner ou modifier le comportement des payloads.

Outils qu'on pratique en cours :

Metasploit - exploiter des vulnérabilités et obtenir un accès initial à une machine, permet de livrer les payloads, mettre les backdoors etc.

Mimikatz est utilisé après la compromission pour extraire des secrets d'authentification en mémoire, les hashes des mdp, les tickets kerberos etc.

Phase 7 : Reporting

Communication : définir avec le client quand et comment communiquer (alertes critiques, rapports périodiques).

Contenu essentiel :

- Résumé exécutif (risques, impacts, priorités).
- Portée et méthodologie du pentest.
- Constatations analysées (validation, pas de faux positifs).
- Évaluation des risques (ex. CVSS).
- Recommandations techniques et organisationnelles.

Niveau de détail : adapté au public (direction vs équipes techniques).

Documentation : réalisée tout au long du pentest (notes, captures).

Confidentialité : rapport classifié, diffusion contrôlée.

Après remise : acceptation écrite du client et destruction des données sensibles.

Les Antennes

Généralités

Une antenne convertit l'énergie électrique fournie en ondes électromagnétiques et vice versa.

La manière dont une antenne va rayonner l'énergie dépend de sa forme et des matériaux qui la compose.

La **résistance de rayonnement** est une résistance fictive qui, mise à la place de l'antenne, dissiperait en chaleur la même puissance que celle qui est rayonnée par l'antenne. Valeur utilisée pour l'adaptation d'impédance.

Bande passante (Bande fréquentielle) – Bande de fréquences dans laquelle une antenne peut émettre et recevoir.

La **polarisation** d'une antenne décrit l'orientation des lignes de force du champ électrique par rapport à la terre. Peut être verticale, horizontale ou circulaire. Pour une meilleure performance utiliser le même type en émission et en réception.

Le **gain d'antenne** mesure la capacité d'une antenne à concentrer l'énergie radio dans une direction donnée par rapport à une antenne de référence.

- Gain élevé = loin mais étroit
- Gain faible = proche mais large
- dBi : gain par rapport à une antenne isotropique (référence théorique).
- dBd : gain par rapport à un dipôle demi-onde (référence réelle).

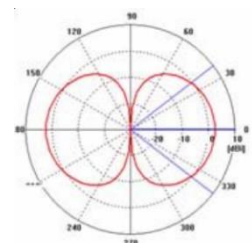
Effective Isotropic Radiated Power (EIRP) – puissance réellement émise par l'antenne avec le gain.

Diagramme de rayonnement – on vient couper le champ de rayonnement en 3d verticalement et horizontalement.

Directivité de l'antenne – angle où on estime que l'antenne rayonne bien, et perd moins que 50% de puissance. Se calcule à l'endroit de -3Db.

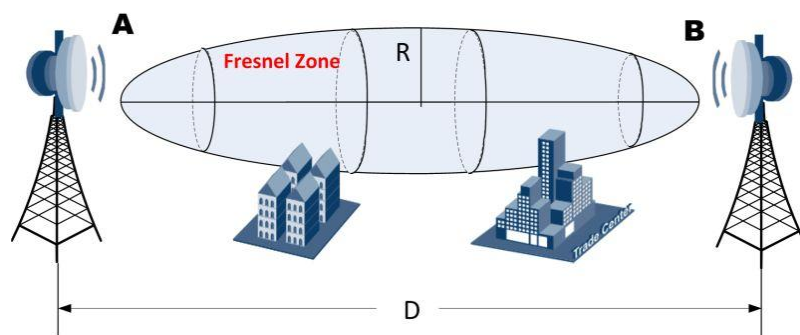
Plan H – horizontal.

Plan E – vertical.



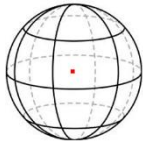
SNR, Signal to Noise Ratio - rapport qui permet de comparer le niveau des ondes utiles avec celui des interférences.

Zone de Fresnel (L'Ellipsoïde de Fresnel) - délimite la région de l'espace où est véhiculée la plus grande partie de l'énergie du signal. Si les obstacles de cette zone ne bloquent pas plus de 40% du signal (20% avec marge), la propagation se passe comme dans les conditions de la propagation en espace libre.

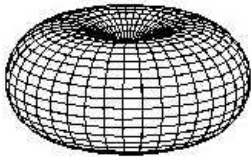


Types d'antennes

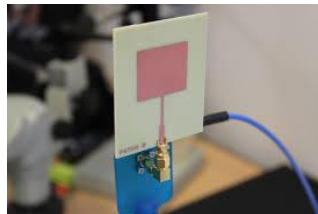
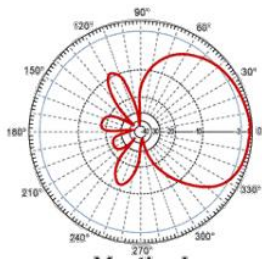
- **Antenne isotropique** – antenne « idéale » (théorique) qui rayonne de la même manière dans toutes les directions (). (gain = 0dBi)



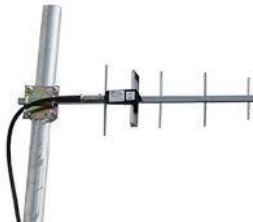
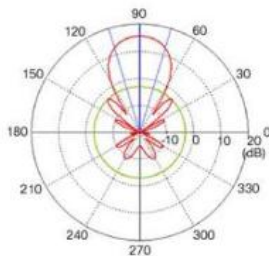
- **Antenne directionnelle** – concentre rayonnement dans une direction précise.
- **Omnidirectionnelle** – rayonne dans toutes les directions (terme général).
- **Dipôle** ($\lambda/2$) – rayonne en forme de donut horizontalement.



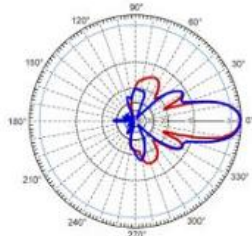
- **Antenne patch** - semi directionnelle.



- **Antenne Yagi** – directionnelle.



- **Antenne parabolique** – directionnelle



Types d'onde

Onde de sol (surface)

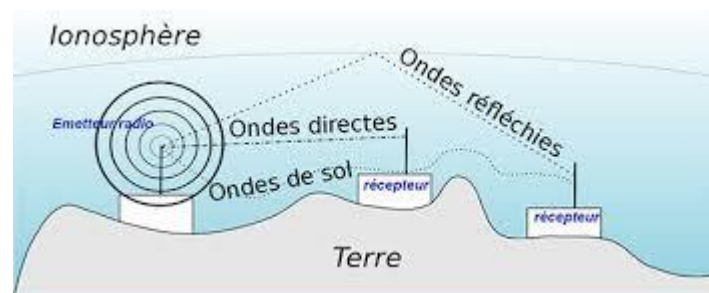
- Se propage le long de la surface terrestre.
- Indépendante des conditions atmosphériques.
- Utilisable à **basses fréquences** (kHz à ~1 MHz).

Onde d'espace (directe et réfléchie)

- Dominante pour les fréquences > **30 MHz**
- Composée d'une onde directe et d'ondes réfléchies.
- Sensible aux obstacles dont la taille est supérieure à la longueur d'onde.

Onde de ciel

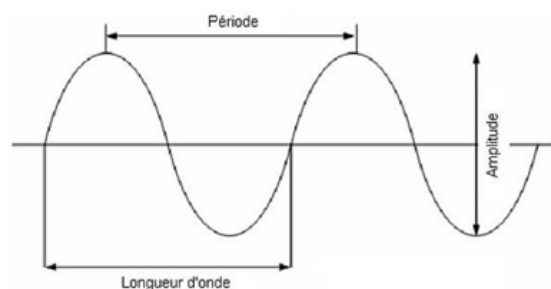
- Interaction avec l'**ionosphère**.
- Dépend de l'activité solaire et des cycles jour/nuit et saisonniers.
- Peut être absorbée, réfractée ou réfléchie selon l'angle d'incidence et le milieu.



L'onde radio (Radio wave)

- Utilisé par Wi-Fi
- Fait partie de la famille des ondes électromagnétiques
- Une onde électromagnétique est constituée d'oscillations générées par un courant alternatif.
- Plus la fréquence est élevée, plus l'onde s'atténue rapidement.
- Débit élevé → nécessite un signal fort pour lire correctement par le récepteur → courte portée.
- Débit faible → tolère un signal plus faible → longue portée.

Période : T
 Fréquence : f
 Longueur d'onde : λ
 Phase : ϕ
 Vitesse de propagation : v



Les ondes électromagnétiques sont constituées par deux champs : l'un électrique, l'autre magnétique, tous deux en phase et perpendiculaires l'un à l'autre.

Received Signal Strength Indicator - mesure qui décrit la quantité de puissance du signal qui arrive au niveau du récepteur. Peut être exprimée en une échelle décimale (par exemple) entre 0 et 255. Chaque valeur correspondant à une valeur en dBm. Ou directement en dBm. En Wi-Fi les valeurs usuelles de RSSI pour une station varient de -30 à -90 dBm. Utilisé par les appareils pour choisir une antenne de réception parmi plusieurs par ex.

MAC Address	SSID	RSSI	Channel
00:1C:F0:8B:30:E3	BlueFed	-39	3
00:1E:E5:86:37:DA	Moon	-89	6
00:24:78:27:84:00	myquest1119	-72	1
00:16:B6:DC:49:E9		-82	1
00:24:01:2A:29:7C	Nivea	-69	8
E0:93:F5:63:EB:6A	KARANTH	-87	1
00:23:69:93:68:F8	laurels	-92	1
00:24:01:44:1F:9E	Mop	-90	1
00:16:B6:BA:11:5A	CaganJoe	-94	6
00:30:8D:F8:D4:80	noentry	-92	6

Les incidents de propagation

- **Atténuation en espace libre**

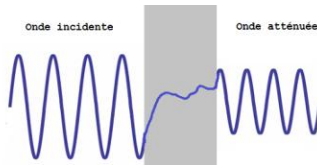
- L'intensité de l'onde diminue avec la distance à l'émetteur.
- La **sensibilité du récepteur** détermine sa capacité à capter des signaux faibles. Le signal reçu doit être plus puissant que la sensibilité du récepteur.

- **Réflexion**

- L'onde peut être réfléchiée totalement ou partiellement par un obstacle.
- Le plastique et le verre réfléchissent bien les ondes Wi-Fi.



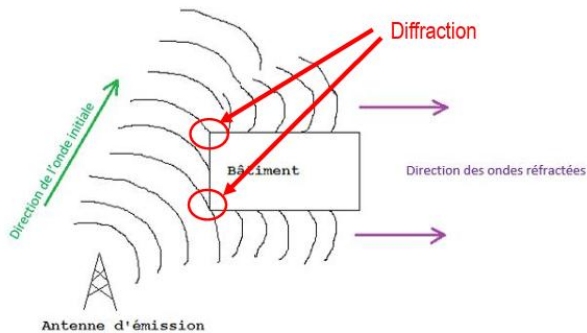
- **Absorption** - une partie de l'énergie de l'onde est absorbée par l'obstacle.



- **Réfraction** - l'onde traverse un matériau (verre, eau) et change de direction.



- **Diffraction** - L'onde contourne un obstacle ou une ouverture, modifiant sa trajectoire.



- **Diffusion** - l'onde est dispersée lorsqu'elle rencontre un obstacle de taille proche de sa longueur d'onde ou une surface irrégulière.



- **Fading** – effet d'évanouissement du signal. L'onde arrive directe et réfléchiée vers l'antenne, donc l'antenne fait la somme des deux, qui est proche de 0 là où les ondes sont complètement opposées.

Calcul de l'angle de directivité

